

SISP - Sociedade Interbancária e Sistemas de Pagamento

Pagamento Web - Especificação do Protocolo de Segurança

NOTA DE CONFIDENCIALIDADE

Este documento tem carácter confidencial e não deverá ser duplicado, publicado ou divulgado, na totalidade ou parcialmente, a terceiros sem autorização prévia da SISP.

Índice

1	Enquadramento	5
1.1	Objectivo.....	5
1.2	Definições	5
2	segurança	5
2.1	Principais Problemas	5
2.2	<i>FingerPrint</i>	6
2.3	Como o <i>FingerPrint</i> Resolve os Principais Problemas	6
2.4	Geração do <i>FingerPrint</i>	6
2.4.1	Comerciante - Como gerar um <i>FingerPrint</i>	6
2.4.2	SISP - Gerando o <i>Fingerprint</i> da Resposta	8

Título do Documento:	Pagamento Web - Especificação do Protocolo de Segurança
Versão do Documento:	1.1
Data de Criação:	Outubro 2018
Data de Actualização:	Março 2020
Documentos Relacionados:	
Documento produzido por:	SISP - Sociedade Interbancária e Sistemas de Pagamentos, SARL.

Histórico de Versões

Data	Autor		Versão	Descrição
	Feito por:	Verificado por:		
Outubro 2018	SISP/LZ	SISP/JG	1.0	Criação
Março 2020	SISP/LZ	SISP/JG	1.1	Actualização dos parâmetros
Maio 2020	SISP/MR	SISP/JG	2.0	Actualização formula de Cálculo FingerPrinter

1 ENQUADRAMENTO

1.1 Objectivo

Este documento objectiva informar os comerciantes que decidiram implementar o serviço de pagamento online, como construir o campo de *hash* para enviar para o MPI e como validar o campo de *hash* que o MPI retorna.

O objectivo principal de construir esse valor *hash* é fortalecer a segurança/integridade dados no canal de comunicação de duas formas:

- Validar integridade de dados;
- Validar a origem dos dados.

1.2 Definições

- **FingerPrint** - Valor de *hash*;
- **FingerPrintVersion** - versão do *hash*;
- **Função hash** - É um algoritmo que mapeia dados de comprimento variável para dados de comprimento fixo;
- **MPI (Merchant Plug-In)** - É a aplicação responsável pelo processamento das transacções na internet de acordo com a especificação 3D-Secure;
- **SHA-512** - Significa *secure hash algorithm* (algoritmo de *hash* seguro), que é um conjunto de funções *hash* criptográficas projectadas pela Agência de Segurança Nacional dos EUA;
- **UTF-8** - Significa 8-bit *Unicode Transformation Format* e é um tipo de codificação binária (Unicode) de comprimento variável. Pode representar qualquer carácter universal padrão do Unicode;
- **Valor de hash** - Valor que não pode ser revertido e que é resistente à colisão.

2 SEGURANÇA

2.1 Principais Problemas

O principal problema é garantir as seguintes necessidades:

- Qualquer mensagem enviada do comerciante, não pode ser alterada por qualquer pessoa no meio do canal sem ser detectada a violação (integridade de dados do comerciante a SISP);

- As mensagens resultantes enviadas de volta a SISP para o Comerciante não podem ser alteradas por ninguém no meio do canal sem ser detectada a violação (integridade de dados da SISP ao comerciante);
- A origem da mensagem deve ser validada para ambos os lados.

2.2 *FingerPrint*

FingerPrint é um valor de *hash* gerado com base nos valores da mensagem a ser enviada. Para tornar a operação segura. Assim o *FingerPrint* deve ter:

- Valores Dinâmicos - valores gerados e diferentes a cada operação;
- Valor oculto - um valor que é conhecido apenas pelas partes que precisam gerar o *hash*.

2.3 Como o *FingerPrint* Resolve os Principais Problemas

Há um *FingerPrint* gerado para cada mensagem de pedido enviada pelos comerciantes e para cada mensagem de resposta da SISP.

Um *FingerPrint* gerado pelo comerciante deve ser validado pela SISP e um *FingerPrint* gerado pela SISP deve ser validado pelo comerciante.

Se um único bit da mensagem for alterado, a função *hash* que gera o *FingerPrint* dará a garantia de que o resultado do *hash* é completamente diferente. Assim, os valores enviados para ambos os lados podem ser validados (se os valores originais forem iguais aos valores recebidos), gerando o *hash* no destino com valores recebidos e comparando com o *hash* recebido.

Não há como alterar o *hash* no meio do canal de comunicação, porque é necessário usar o valor oculto que apenas a origem e o destino conhecem.

Para tornar ainda mais difícil reverter o valor de *hash* para os valores originais, são usados valores dinâmicos diferentes para cada mensagem.

2.4 Geração do *FingerPrint*

O *FingerPrint* deve ser gerado usando o algoritmo SHA-512 sobre os bytes de uma mensagem UTF-8 codificada.

Os parâmetros devem ser concatenados pela ordem apresentado na tabela abaixo.

Os valores dos parâmetros recebidos na resposta devem ser usados como recebidos e de acordo com o especificado na tabela abaixo.

2.4.1 Comerciante - Como gerar um *FingerPrint*

A mensagem é formada concatenando os campos conforme descrito abaixo sem nenhum separador.

Campo	Tipo	Descrição
posAutCode	Base64 Encoded	POS Authentication Code deve ser criptografado com SHA-512 e o resultado deve ser codificado em Base64. Esse é o campo com valor oculto que deve ser conhecido apenas pelo comerciante e pela SISP.
timeStamp	Varchar	TimeStamp da mensagem deve ser formatada como yyyy-MM-dd HH:mm:ss
Amount	Long	O montante da transacção deve ser multiplicado por 1000 e deve ser usado apenas como parte inteira do resultado. Ex.: Se o montante é 5432.98 deve ser enviado como 5432980.
merchantRef	Varchar	Referência de pagamento, gerado pelo sistema do comerciante. Esse campo deve ser formatado de forma a eliminar todos os espaços em branco na mensagem.
merchantSession	Varchar	Identifica a sessão do cliente no portal do comerciante, gerado pelo sistema do comerciante. Esse campo deve ser formatado de forma a eliminar todos os espaços em branco na mensagem.
posID	Varchar(8)	Identifica o terminal virtual do comerciante na rede vinti4. Deve ser gerado pela SISP e atribuído ao comerciante. Esse campo deve ser formatado de forma a eliminar todos os espaços em branco na mensagem.
Currency	Varchar(3)	Código de moeda da transacção. Deve ser preenchido sempre com valor "132". Deve ser eliminado espaços e zeros a esquerda.
transactionCode	Varchar(1)	Indica o tipo de transacção que se está a iniciar. Esse campo deve ser formatado de forma a eliminar todos os espaços em branco na mensagem.
entityCode	Long(5)	Este campo é usado apenas no caso de Carregamento de Telemóvel ou Pagamento de Serviço. Assim, somente deve ser considerado no <i>hash</i> , caso for usado. Se este campo for usado, ele não deve conter zero caracteres à esquerda. Ex.: • O valor 00001 deve ser 1; • O valor 00100 deve ser 100; • O valor 10001 deve ser 10001.
referenceNumber	Long (7)	Este campo é usado apenas no caso de Carregamento de Telemóvel ou Pagamento de Serviço. Assim, somente deve ser considerado no <i>hash</i> , caso for usado. Se este campo for usado, ele não deve conter zero caracteres à esquerda. Ex.: • O valor 000001 deve ser 1; • O valor 001000 deve ser 1000. • O valor 100001 deve ser 100001.

Após a concatenação de todos campos deve se gerar um *hash* usando o SHA-512 e o resultado deve ser codificado em Base64.

2.4.2 SISP - Gerando o *Fingerprint* da Resposta

Cada resposta enviada da SISP ao comerciante tem um *FingerPrint*, que foi gerado usando SHA-512 de uma mensagem formada concatenando os campos conforme abaixo descrito, sem qualquer separador. Sendo que, os campos utilizados dependem do tipo de mensagem.

2.4.2.1 Resposta de sucesso

Para mensagem do tipo (**messageType**) 8, 10, P e M são considerados os seguintes campos para a geração do *FingerPrint*:

Campo	Tipo	Descrição
posAutCode	Base64 Encoded	POS Authentication Code deve ser criptografado com SHA-512 e o resultado deve ser codificado em Base64. Esse é o campo com valor oculto que deve ser conhecido apenas pelo comerciante e pela SISP. Exemplo: posAutcode "123456789A" o valor é "TrmzQzqPgdcicNXUMMKu8p+rtbSoqZDkXeHBZVeZdkyY/B hPZKArQpCJAP4GsPaJbviDg51P8iYlyohDjNr52w=="
messageType	Varchar	Deve ser concatenado eliminado todos os espaços no início e no fim.
merchantRespCP	Varchar	Período Contabilístico em que a transação se realizou. Esse campo deve ser formatado de forma a eliminar todos os espaços em branco na mensagem. Exemplo: Valor recebido "0000100" deve ser concatenado "100" Valor recebido "100" deve ser concatenado "100"
merchantRespTid	Varchar	Esse campo deve ser formatado de forma a eliminar todos os espaços em branco na mensagem. Exemplo: Valor recebido "0000100" deve ser concatenado "100" Valor recebido "100" deve ser concatenado "100"
merchantRespMerchantRef	Varchar	Deve ser concatenado eliminado todos os espaços no início e no fim.
merchantRespMerchantSession	Varchar	Deve ser concatenado eliminado todos os espaços no início e no fim.
merchantRespPurchaseAmount	Long	O montante da transação deve ser multiplicado por 1000 e deve ser usado apenas como parte inteira do resultado. Exemplo.: O montante é "500" deve ser enviado como "500000".
merchantRespMessageID	Varchar	Deve ser concatenado eliminado todos os espaços no início e no fim.
merchantRespPan	Varchar	Deve ser concatenado eliminado todos os espaços no início e no fim.
merchantResp	Varchar	Deve ser concatenado eliminado todos os espaços no início e no fim.
merchantRespTimeStamp	Varchar	TimeStamp da mensagem deve ser formatada como yyyy-MM-dd HH:mm:ss

merchantRespEntityCode	Long	Este campo é usado apenas no caso de Carregamento de Telemóvel ou Pagamento de Serviço. Assim, somente deve ser considerado no <i>hash</i> , caso for usado. Se este campo for usado, ele não deve conter zero caracteres à esquerda. Exemplo.: - O valor 00001 deve ser 1; - O valor 10001 deve ser 10001.
merchantRespReferenceNumber	Long	Este campo é usado apenas no caso de Carregamento de Telemóvel ou Pagamento de Serviço. Assim, somente deve ser considerado no <i>hash</i> , caso for usado. Se este campo for usado, ele não deve conter zero caracteres à esquerda. Exemplo.: - O valor 00001 deve ser 1; - O valor 00100 deve ser 100; - O valor 10001 deve ser 10001.
merchantRespClientReceipt	Varchar	Deve ser concatenado eliminado todos os espaços no início e no fim.
merchantRespAdditionalErrorMessage	Varchar	Deve ser concatenado eliminado todos os espaços no início e no fim.
merchantRespReloadCode	Varchar	Código de Recarga. Este campo é preenchido a zero quando uma operação de recarga se realiza em RealTime. Esse campo deve ser formatado de forma a eliminar todos os espaços. Exemplo.: - O "" (vazio) deve ser ""(vazio); - O valor 000000000000 deve ser 000000000000; - O valor 999999999999 deve ser 999999999999.

PARAMETRO RECEBIDOS NA RESPOSTA

messageType: 8
 merchantRespCP: 987
 merchantRespTid: 26
 merchantRespMerchantRef: R20200517133227
 merchantRespMerchantSession: S20200517133227
 merchantRespPurchaseAmount: 1000.00
 merchantRespMessageID: J38HvwHPPn22P1se00xJ
 merchantRespPan: *****3335
 merchantResp: C
 merchantRespErrorCode:
 merchantRespErrorDescription:
 merchantRespErrorDetail:
 languageMessages: pt
 merchantRespTimeStamp: 2020-05-17 13:30:48
 merchantRespReferenceNumber:
 merchantRespEntityCode:
 merchantRespClientReceipt:
 merchantRespReloadCode:
 merchantRespAdditionalErrorMessage:

```
resultFingerPrint:
URCdX5Y4D4YW1afldlbdRMx+FDAt//jdvFJreGUZC98n2xepsGcAlgrWUPQj4n+lcWS04Dm9kNGY4G1N82
pPeQ==
resultFingerPrintVersion: 1
```

TRATAMENTO POSAUTCODE

```
posAutCode "ttqRdOzmGvCSpuag"
posAutCode aplicado hash
"Db9k/Mqg6dLNrdKseAdLTm7p6201cofJb6Vmpttz5+ZVCSosgKq9h8wMZR6psKFhPKPP2mZWOj4tAMhKfDV4g=="
```

PARAMETROS CONCATEADOS

```
Db9k/Mqg6dLNrdKseAdLTm7p6201cofJb6Vmpttz5+ZVCSosgKq9h8wMZR6psKFhPKPP2mZWOj4tAMhKfDV4g==898726R20200517133227S202005171332271000000J38HvwHPPn22P1se00xJ*****3335C2020-05-17 13:30:48
```

RESULTADO FINAL DO HASH

```
URCdX5Y4D4YW1afldlbdRMx+FDAt//jdvFJreGUZC98n2xepsGcAlgrWUPQj4n+lcWS04Dm9kNGY4G1N82
pPeQ==
```

Sucesso

2.4.2.2 Resposta de erro

Para mensagem de erro (**messageType = 6**) são considerados os seguintes campos para a geração do *FingerPrint*:

Campo	Tipo	Descrição
posAutCode	Base64 Encoded	POS Authentication Code deve ser criptografado com SHA-512 e o resultado deve ser codificado em Base64. Esse é o campo com valor oculto que deve ser conhecido apenas pelo comerciante e pela SISP. Exemplo: posAutcode "123456789A" o valor é "TrmzQzqPgdcicNXUMMKu8p+rtbSoqZDkXeHBZVeZdkyY/BhPZKArQpCJAP4GsPaJbviDg"

		51P8iYlyohDjNr52w=="
messageType	Varchar	Valor = 6. Deve ser concatenado eliminado todos os espaços no inicio e no fim.
merchantRespMessageID	Varchar	Deve ser concatenado eliminado todos os espaços no inicio e no fim.
merchantRespErrorCode	Varchar	Código de Erro resultante do processamento da transacção. Esse campo deve ser formatado de forma a eliminar todos os espaços em branco na mensagem.
merchantRespErrorDetail	Varchar	Deve ser concatenado eliminado todos os espaços no inicio e no fim.
merchantRespErrorDescription	Varchar	Deve ser concatenado eliminado todos os espaços no inicio e no fim.
merchantRespMerchantRef	Varchar	Deve ser concatenado eliminado todos os espaços no inicio e no fim.
merchantRespMerchantSession	Varchar	Deve ser concatenado eliminado todos os espaços no inicio e no fim.
merchantRespAdditionalErrorMessage	Varchar	Deve ser concatenado eliminado todos os espaços no inicio e no fim.
merchantRespTimeStamp	Varchar	TimeStamp da mensagem deve ser formatada como yyyy-MM-dd HH:mm:ss

Exemplo:

PARAMETRO RECEBIDOS NA RESPOSTA

messageType: 6
 merchantRespMerchantRef: R20200517185116
 merchantRespMerchantSession: S20200517185116
 merchantRespMessageID: 15CJ2GtDCOy5578q64a1
 merchantRespErrorCode: 2
 merchantRespErrorDescription: A autenticao 3D Secure falhou.
 merchantRespErrorDetail: VEREnrollRes
 languageMessages: pt
 merchantRespTimeStamp: 2020-05-17 18:51:41
 merchantRespReferenceNumber:
 merchantRespEntityCode:

merchantRespClientReceipt:

merchantRespReloadCode:

merchantRespAdditionalErrorMessage: PASSWORD ERRADO. FAVOR TENTAR NOVAMENTE.

resultFingerPrint:

AYpWZLwKhNwXtfDAW4l15D9oM3fVtJOwZkKt89djbAZP+L2FW/hPuHeyMQQVmX16xvmoSzRptSNcM5AGy0Y93w==

resultFingerPrintVersion: 1

TRATAMENTO POSAUTCODE

posAutCode "ttqRdOzmGvCSpuag"

posAutCode aplicado hash

"Db9k/Mqg6dLNrdKseAdLTm7p6201cofJb6Vmpttz5+ZVCSosgKq9h8wMZRx6psKFhPKPP2mZWOj4tAMhKfDV4g=="

PARAMETROS CONCATENADOS

Db9k/Mqg6dLNrdKseAdLTm7p6201cofJb6Vmpttz5+ZVCSosgKq9h8wMZRx6psKFhPKPP2mZWOj4tAMhKfDV4g==615C

J2GtDCOy5578q64a12VEREnrollResA

autenticacao

3D

Secure

falhou.R20200517185116S20200517185116PASSWORD ERRADO. FAVOR TENTAR NOVAMENTE.2020-05-17 18:51:41

RESULTADO FINAL DO HASH

AYpWZLwKhNwXtfDAW4l15D9oM3fVtJOwZkKt89djbAZP+L2FW/hPuHeyMQQVmX16xvmoSzRptSNcM5AGy0Y93w==